

What Is DAST, How It Works, and 5 Key Considerations

What Is Dynamic Application Security Testing (DAST)?

Dynamic application security testing (DAST) is a type of security testing that focuses on evaluating the security of a web application while it is running. Unlike static testing, which analyzes the source code of an application, dynamic testing examines the application's behavior and interactions with the runtime environment.

DAST aims to identify vulnerabilities and security weaknesses in a web application by simulating real-world attacks and attempting to exploit them. This can include testing for common web application threats such as cross-site scripting (XSS), SQL injection (SQLi), and cross-site request forgery (CSRF).

DAST tools automate the process of testing web applications and provide detailed reports on the identified security vulnerabilities and weaknesses. These reports can be used by developers to fix issues and improve the security of the application.

DAST is a crucial aspect of software security and is often used in combination with other types of testing, such as static testing and penetration testing, to provide a comprehensive security assessment.

This is part of a series of articles about [application security](#).

How Does DAST Work?

DAST works by actively interacting with a web application while it is running. The testing process typically involves the following steps:

- **Scanning:** The DAST tool scans the target web application to identify the entry points and assess the overall security posture of the application. This includes identifying the different components of the application, such as URLs, forms, and APIs.

- **Attack simulation:** The DAST tool simulates real-world attacks by sending requests to the application and attempting to exploit vulnerabilities. This includes testing for common web application threats such as XSS and CSRF.
- **Vulnerability detection:** The DAST tool analyzes the responses from the application to determine if any vulnerabilities or security weaknesses have been exposed. If a vulnerability is detected, the DAST tool will generate a report indicating the type and severity of the issue.
- **Reporting:** The DAST tool provides a detailed report on the findings of the test, including information on the vulnerabilities discovered and recommendations for remediation. This report can be used by developers to fix the issues and improve the security of the application.

DAST tools typically use a combination of manual and automated testing techniques to perform a thorough security assessment of the web application. The testing process is often repeated at regular intervals or runs continuously to ensure that the application remains secure over time.

Learn more in our detailed guide to [application security testing](#).

DAST vs. SAST: What Are the Differences?

DAST and static application security testing (SAST) are two different approaches to evaluating the security of a web application. The main differences between DAST and SAST are:

- **Timing:** DAST is performed after the application is deployed and running in a production environment, while SAST is performed on the application's source code before it is deployed.
- **Approach:** DAST evaluates the security of an application by actively interacting with it while it is running, while SAST analyzes the application's source code to identify potential vulnerabilities and security weaknesses.
- **Coverage:** DAST focuses on testing the application from an external perspective, simulating real-world attacks and attempting to exploit vulnerabilities. SAST, on the other hand, examines the application's static source code to identify vulnerabilities and security weaknesses that could potentially be exploited during runtime.
- **Results:** DAST can identify vulnerabilities and security weaknesses in the application's runtime environment, including issues that may not be present in the source code. SAST provides a comprehensive analysis of the application's code, including potential security vulnerabilities and architectural weaknesses.

In conclusion, both DAST and SAST are important components of a comprehensive security program. DAST provides a real-world assessment of the application's security posture, while

SAST provides a comprehensive analysis of the application's code and architecture. The two techniques should be used in combination to provide a complete security assessment of a web application.

5 Key Considerations for Choosing DAST Tools

Here are several factors to consider when choosing a DAST tool:

1. **Visibility into all applications:** In order to have a comprehensive view of your organization's security posture, it's important to choose a DAST solution that can perform web asset discovery across all your public-facing assets, including multiple websites and applications. This will ensure that you have visibility into all the potential attack points in your environment.
2. **Scanning depth and accuracy:** The accuracy and completeness of the results produced by a DAST tool depend on its ability to crawl the target applications and identify all the application inputs. It's important to choose a tool with a comprehensive crawling and scanning engine that can interpret the application architecture and frameworks you use, including JavaScript stacks.
3. **Streamlined remediation:** Once vulnerabilities have been identified, it's vital to address them quickly, especially in a production environment. Choose a DAST solution that provides actionable vulnerability reports to help developers fix issues without lengthy, cumbersome, back-and-forth exchanges with security teams. The solution should provide detailed reports that help isolate the root cause of each vulnerability, deliver proof-of-exploit evidence that shows you're not wasting time on false positives, and recommend mitigation actions.
4. **Compliance reporting:** If your organization is subject to governmental or industry-specific compliance and security requirements, it's important to choose a DAST solution that automates compliance reporting. Look for a solution that automates reporting for standards such as the PCI DSS, HIPAA, and ISO/IEC 27001, as these reports can help identify areas that need to be addressed and demonstrate that you have the security testing processes needed for compliance.
5. **Product maturity and vendor expertise:** The DAST solution you choose will be relied on to perform accurately over the long term, so it's important to examine each supplier's track record and market commitment. Consider how long the product has existed and the vendor's existing successful case studies. Choose a vendor that offers frequent product updates and support and services to supplement your security expertise.

It's also important to consider the specific needs of your organization and your application when choosing a DAST tool. You may want to consider evaluating a few different tools before making a final decision, and seek input from your development and security teams to ensure that the tool you choose will meet your organization's needs and requirements.

How HackerOne Goes Beyond DAST

Dynamic Application Security Testing is a great way to detect exploitable vulnerabilities affecting applications with a web interface. However, DAST scanners don't possess the intuition of a human attacker and, by themselves, can leave unchecked gaps in your attack surface. Furthermore, like other automated scanners, DAST is prone to false positives that can easily overwhelm developers and lead to questions on the validity of results.

Human security experts are able to mimic a real cybercriminal to detect vulnerabilities affecting web applications and flag exploits that automated scanners miss such as authorization issues and business logic errors. More importantly, adversarial testing results from humans provides a level of validity for developers and drives urgency to fix vulnerable code.

HackerOne scales security with on-demand, highly skilled experts that deliver a full spectrum of adversarial application testing. The HackerOne Attack Resistance Platform inventories your digital assets while pinpointing the most critical flaws. Ethical hackers then test your attack surface from an adversarial point of view to find the vulnerabilities most likely to be exploited by bad actors.

[Learn more about the HackerOne Attack Resistance Platform](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a  hacker?

Trust